

Guía de estudio y demostración

Proyecto académico · Versión completa local · 15/09/2026

Cómo se comunican las tres partes

Angular recibe lo que escribe el estudiante y dibuja resultados. Express decide si la operación está permitida, valida datos y prepara consultas. MySQL conserva la información después de cerrar el navegador o reiniciar Node.

Una API REST es un conjunto de direcciones con operaciones HTTP: GET consulta y POST crea. JSON es el formato de intercambio. La cookie identifica la sesión; Angular no puede leerla porque es HttpOnly.

Recorrido de una publicación

1. `new-post.ts` consulta `/catalogs` y muestra opciones.
2. `ngModel` enlaza controles con `type`, `targetId` y `message`.
3. `save()` llama a `Api.post` en `core.ts`.
4. `HttpClient` envía JSON a `/api/posts`; el navegador adjunta la cookie.
5. `app.js` ejecuta autenticación antes de las rutas internas.
6. `auth.js` busca hash del token, comprueba caducidad y carga `req.user`.
7. `routes-posts.js` valida con Zod el mensaje y un solo destino.
8. `db.js` ejecuta INSERT parametrizado con `req.user.id`; MySQL fija fecha.
9. MySQL comprueba claves foráneas y CHECK.
10. Express devuelve 201 y la publicación completa. Angular regresa al listado y consulta datos persistentes.

Qué archivos estudiar

Primero `database/schema.sql`. Después `backend/src/app.js`, `auth.js`, `routes-posts.js` y `validation.js`. En Angular empezar por `routes.ts`, `core.ts`, `new-post.ts` y `feed.ts`. Comentarios y perfiles repiten el mismo patrón.

```
await query("INSERT INTO comments(post_id,author_id,message) VALUES(?,?,?)", [
  postId,
  req.user.id,
  b.message,
]);
```

Los valores se separan de la instrucción SQL. Las comillas del mensaje se guardan como texto, no se ejecutan como SQL.

Guion de demostración (10-12 minutos)

1. Explicar arquitectura y cuatro carpetas (1 min).

2. Registrar una cuenta nueva y mostrar redirección y rechazo duplicado (1 min).
3. Login incorrecto y correcto (1 min).
4. Publicar sobre curso y docente, mostrar orden, filtros y Limpiar (2 min).
5. Cerrar sesión, entrar como segunda cuenta y comentar; recargar (1 min).
6. Buscar perfiles existente/inexistente; comparar permisos propio/ajeno. Agregar dos cursos y explicar suma (2 min).
7. Explicar recuperación y limitación académica; usar cuenta de prueba (1 min).
8. Mostrar restricciones SQL y resultados de tests/build (2 min).

Preparar MySQL antes de la calificación. El catálogo está incluido y no se necesita Internet para las pantallas. No cambiar a main durante la demostración: contiene el avance parcial.

Preguntas posibles

¿Por qué no basta deshabilitar un botón? Se puede llamar directamente a la API. Express compara req.user.id y devuelve 403 para recursos ajenos.

¿Dónde se guarda la contraseña? En users.password_hash con bcrypt, sal individual y costo 12. Se comprueba con bcrypt.compare y nunca se devuelve al cliente.

¿Hash y cifrado son iguales? No. El cifrado permite recuperar un dato con una clave. El hash permite comparar sin recuperar la contraseña original.

¿Cómo evitas registros duplicados? UNIQUE en MySQL y respuesta HTTP 409. Funciona incluso con solicitudes simultáneas.

¿Cómo impides dos destinos? Zod exige exclusión y CHECK SQL comprueba que un destino sea nulo y el otro no.

¿Por qué el formulario no envía autor? Para impedir suplantación. Se obtiene de la sesión del servidor.

¿Diferencia entre 401 y 403? 401 significa sesión ausente/inválida; 403 significa operación no permitida para ese usuario.

¿Qué es una clave foránea? Una relación que obliga a que exista el registro referenciado; un comentario no puede apuntar a una publicación inexistente.

¿Cómo evitas cursos duplicados? Clave primaria compuesta (user_id, course_id).

¿Dónde se calculan los créditos? En el servidor, con los créditos consultados mediante JOIN. No se confía en un total enviado por el navegador.

¿Qué ocurre al reiniciar Node? Datos y sesiones siguen en MySQL. persistence.test.js detiene y reinicia un proceso para comprobarlo.

¿Cómo se filtra? Angular envía query params. Express combina condiciones permitidas mediante AND y ordena fecha e ID descendentes.

¿Por qué guardar hash del token? Para no almacenar en la tabla el secreto que se utiliza como cookie. Un hash filtrado no se puede usar directamente como token.

¿Qué hace CORS? Controla qué orígenes pueden leer respuestas desde el navegador. No sustituye autenticación ni permisos. Se comprueba también Origin en escrituras.

¿Por qué recuperación usa transacción? Actualiza contraseña y elimina sesiones como una unidad; ante fallo se revierte.

¿Los aprobados son oficiales? Son declaraciones del usuario con nombres/créditos oficiales de referencia; no una certificación institucional.

¿Por qué CLAR? Se eligió el plan publicado como vigente desde 2025 y se documentó para no mezclar escalas.

¿Qué falta para publicar una aplicación real? Verificación fuerte de recuperación, HTTPS, políticas de datos, moderación y operación. El despliegue público queda fuera del encargo.

Práctica recomendada

Para cada acción, localizar el componente, la ruta y la tabla. Después provocar una entrada inválida y explicar qué capa la rechaza. Revisar las pruebas ayuda a comprender restricciones y permisos basados en el código real.